
MEDICARE CONNECT (PTY) LTD INFORMATION SECURITY GAP ANALYSIS REPORT

ISO 27001:2022 AND POPIA COMPLIANCE ASSESSMENT

Classification : Confidential
Version : 1.0
Date : June 2025

Compiled by PV. Mohlala , GRC Analyst

1. PURSOPE

This Gap analysis identifies the difference between Medicare connect's current information security posture and the requirement of

- ISO 27001:2022 (Information Security)
- POPIA (Protection of Personal Information Act)

2. METHOLOGY

Assessment approach :

- Document review
- Stakeholder interview
- Technical configuration review
- ISO 27001: 2022 Annex A checklist
- POPIA conditions assessment

Maturity scale used :

- 1 = Initial (nothing in place)
- 2 = Developing (some activity)
- 3 = Defined (document)
- 4 = Managed (measured)
- 5 = Optimised (improving)

3. EXECUTIVE SUMMARY

Total control assessed	: 20
Fully implemented	: 0 (0%)
Partially implemented	: 8 (40%)
Not implemented	: 12 (60)

Overall compliance score	: 23%
Target compliance	: 80%
Compliance gap	: 57%

POPIA specific gaps	: 7 critical
ISO 27001 specific gaps	: 13 total

RISK RATING	: HIGH
Immediate action required	

4. CRITICAL GAPS (IMMEDIATE ACTION)

GAP 1 : No Information Security Policy
Severity : Critical
ISO Ref : Clause 5.2 / Annex A.5.1
POPIA Ref : Section 19

Current State:

MediCare Connect has no documented Information Security Policy. Staff have no formal guidance on protecting patient information.

Risk:

Without a policy, staff cannot be held accountable for security failures. POPIA enforcement action possible.

Remediation:

Draft, approve and communicate a master Information Security Policy covering all staff and systems.

Timeline : Month 1
Owner : CEO with GRC Analyst support

GAP 2 : NO INFORMATION OFFICER APPOINTED
Severity : CRITICAL
POPIA Ref : Section 55

Current State:

No Information Officer has been appointed or registered with the Information Regulator of South Africa

Risk::

Non-compliance with POPIA Section 55. Organisation cannot legally receive or respond to Data subject complaints. Administrative fines up to R10 million or imprisonment possible.

Remediation:

1. Appoint a senior staff member as Information Officer
2. Register on Information Regulator portal at info regulator.org.za
3. Publish contact details internally

Timeline : Month 1 (URGENT)
Owner : CEO

GAP 3 : No MULTI-FACTOR AUTHENTICATION
Severity : Critical
ISO REF : Annex A.8.5
POPPIA Ref : Section 19

Current State :

All systems including the patient Health record system use single password authentication only.

Risk :

Compromised passwords give full access to patient medical records. Healthcare systems are primary ransomware targets in South Africa.

Remediation :

1. Enable MFA on Microsoft 365 (free with existing licence)
2. Enable MFA ON patient health record system
3. Require MFA for all remote access

Timeline : Month 1
Owner : IT Manager

GAP 4 : No Incident Response Procedure
Severity : Critical
ISO Ref : Annex A.5.26
POPIA : Section 22

Current State :

No formal incident response plan exists. POPIA requires notification to the Information Regulator within 72 hours of discovering a breach.

Risk :

In the event of a breach, the organisation will not meet 72 hour POPIA notification requirement. Regulatory fines and reputational damage will result.

Remediation :

1. Write incident response plan
2. Include POPIA breach notification procedure with 72 hour timeline.
3. Conduct table simulation
4. Train all staff on reporting incidents

Timeline : Month 2
Owner : IT Manager and GRC Analyst

GAP 5 : No Encryption on Laptops
Severity : Critical
ISO Ref : Annex A.8.24
POPIA Ref : Section 19

Current State :

35 staff laptops contain and can access patient medical records. None have full disk encryption enabled.

RISK:

Stolen or lost laptop amounts to immediate POPIA breach affecting patient data. Healthcare data has the highest value on SA darkweb markets.

REMEDIATION :

1. Enable bitlocker on all windows laptops , also included in windows pro
2. Enable filevault on Mac devices
3. Document encryption status in asset register

Timeline : Month 1
Owner : IT Manager

5.REMEDIATION ROADMAP SUMMARY

MONTH 1 (Critical -Start Immediately):

- Appoint Information Officer
- Write Information Security Policy
- Enable MFA on all systems
- Enable laptop encryption (BitLocker)
- Deploy antivirus to all devices
- Complete asset register

MONTH 2 (High Priority):

- Write Incident Response Plan

- Test POPIA breach notification procedure
- Implement classification scheme
- Document access control process
- Enable firewall rule documentation
- Enforce clear desk policy

MONTH 3 (High Priority):

- Implement centralised logging
- Conduct security awareness training
- Implement quarterly access reviews
- Implement physical access log
- Implement secure device disposal process

MONTH 4 (Medium Priority):

- Conduct vendor assessments (labs/pharmacy)
- Conduct Privacy Impact Assessment
- Review and update all supplier contracts
- Conduct first internal audit

6.COMPLAINE SCORE TRACKER

Current score	: 23%
After Month 1	: 45%
After Month 2	: 62%
After Month 3	: 75%
After Month 4	: 85%
ISO 27001 Target	: 80%+

7. CONCLUSION

MediCare Connect faces significant information security and POPIA compliance gaps that require immediate attention. The organization processes special personal information which carries the highest protection requirements under POPIA .

Failure to address critical gaps exposes the organization to :

- Information regulator enforcement action
- Administrative fines up to R10 million.
- Criminal liability for responsible parties
- Patient safety risk from data breach

Immediate implementation of the remediation roadmap is strongly recommended .

Document Control

Compiled by	: Patrick Vusumuzi Mohlala
Date	: June 2025
Version	: 1.0
Status	: Final
Next Review	: September 2025
